

Análise e Exploração de Vulnerabilidades em Redes Corporativas

Autor: Matheus Guilherme de Campos¹

Orientador: Christiano Piccinin¹

¹Departamento de Engenharia e Tecnologia – Universidade da Região de Joinville – Univille
R. Paulo Malschitzki – Zona Industrial Norte, Joinville – SC, 89219-710

matheus.campos@univille.br

Resumo. *As redes corporativas estão cada vez mais expostas a ameaças cibernéticas, exigindo profissionais capazes de identificar e mitigar vulnerabilidades de forma proativa. Este trabalho apresenta um estudo teórico-prático da análise de vulnerabilidades em ambientes corporativos simulados, combinando metodologias de testes de penetração (pentest) com análise de tráfego de rede utilizando o Wireshark. Por meio de um ambiente laboratorial controlado com máquinas virtuais executando serviços intencionalmente vulneráveis, foram realizados ataques com ferramentas como Nmap, Metasploit, Nessus e Hydra, com captura simultânea de tráfego para análise forense posterior. Os resultados demonstram a efetividade da combinação entre pentest e análise de tráfego para identificação de vetores de ataque, além de fornecer recomendações de hardening de rede e aprimoramento da capacidade de resposta a incidentes.*

1. Introdução

O crescimento contínuo da conectividade nas redes corporativas amplia significativamente a superfície de ataque disponível a agentes maliciosos. De acordo com [Stallings 2017], a segurança da informação deixou de ser uma preocupação exclusiva das equipes de tecnologia para se tornar um pilar estratégico das organizações modernas. Nesse contexto, a capacidade de identificar vulnerabilidades antes que atacantes o façam – prática conhecida como *pentest* ou teste de penetração – tornou-se uma competência essencial para profissionais de cibersegurança.

Paralelamente, a análise de tráfego de rede representa uma das técnicas mais eficazes tanto para a detecção de atividades maliciosas em tempo real quanto para a investigação forense após um incidente. Ferramentas como o Wireshark permitem capturar e interpretar pacotes em trânsito, revelando vetores de ataque, credenciais expostas e padrões de comunicação suspeita [Sanders 2017].

Este trabalho tem como objetivo central realizar uma análise abrangente de vulnerabilidades em uma rede corporativa simulada, demonstrando como a combinação de metodologias de pentest e análise de tráfego com Wireshark pode auxiliar na detecção de ataques, na compreensão dos vetores utilizados e na proposição de contramedidas efetivas. As seções seguintes apresentam a fundamentação teórica que sustenta esta pesquisa.

2. Fundamentação Teórica

2.1. Segurança de Redes Corporativas

2.1.1. A Tríade CIA e Modelos de Ameaça

A segurança da informação em redes corporativas é fundamentada na tríade *Confidentiality, Integrity and Availability* (CIA), que define os três pilares que qualquer solução de segurança deve preservar [Stallings 2017]:

- **Confidencialidade:** garantia de que informações sejam acessíveis apenas a entidades autorizadas, protegendo dados sensíveis de exposição indevida;
- **Integridade:** assegurar que dados não sejam modificados de forma não autorizada, seja em trânsito ou em repouso;
- **Disponibilidade:** garantir que sistemas e serviços permaneçam operacionais e acessíveis aos usuários legítimos quando necessário.

A modelagem de ameaças (*threat modeling*) é a prática estruturada de identificar, classificar e priorizar as ameaças potenciais a um sistema. Segundo [Shostack 2014], o processo envolve quatro perguntas fundamentais: em que estamos trabalhando, o que pode dar errado, o que faremos a respeito e se fizemos um bom trabalho. Ferramentas como o STRIDE (Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, Elevation of Privilege) são amplamente utilizadas para categorizar ameaças em redes corporativas.

2.1.2. Defesa em Profundidade e Perímetro de Rede

O modelo de defesa em profundidade (*Defense in Depth*) preconiza a aplicação de múltiplas camadas de controles de segurança sobrepostas, de modo que a falha de um controle não comprometa toda a infraestrutura [National Institute of Standards and Technology 2020]. Em redes corporativas, esse conceito se traduz tipicamente em uma arquitetura que combina:

- Controles de perímetro: *firewalls*, sistemas de detecção e prevenção de intrusões (IDS/IPS) e *gateways* de segurança;
- Segmentação de rede: zonas desmilitarizadas (DMZ), VLANs e microsegmentação;
- Controles de *endpoint*: antivírus, EDR (*Endpoint Detection and Response*) e políticas de grupo (GPOs);
- Controles de acesso: autenticação multifator (MFA), princípio do menor privilégio e gerenciamento de identidades.

2.1.3. Modelo Zero Trust

O modelo de segurança Zero Trust, formalizado pelo NIST na publicação SP 800-207 [National Institute of Standards and Technology 2020] e originalmente proposto por [Kindervag 2010], representa uma evolução fundamental em relação ao paradigma de perímetro tradicional. O princípio central é que nenhuma entidade – usuário, dispositivo

ou serviço – deve ser confiada automaticamente, independentemente de sua localização na rede. As premissas fundamentais incluem: verificação explícita de identidade a cada acesso; concessão de acesso com privilégio mínimo; e presunção de violação, ou seja, assumir que a rede já está comprometida e agir de acordo.

O framework MITRE ATT&CK [MITRE Corporation 2023] complementa o Zero Trust ao fornecer um mapeamento detalhado das táticas, técnicas e procedimentos (TTPs) utilizados por atacantes reais, organizado em uma matriz que permite às equipes de segurança planejar defesas baseadas em comportamentos adversariais observados empiricamente.

2.2. Metodologias de Pentest

O teste de penetração (*penetration testing* ou *pentest*) é a prática de simular ataques cibernéticos de forma autorizada e controlada sobre um sistema, rede ou aplicação, com o objetivo de identificar vulnerabilidades exploráveis antes que agentes maliciosos o façam [Weidman 2014]. Ao contrário de uma varredura automatizada de vulnerabilidades, o pentest envolve raciocínio criativo, encadeamento de técnicas e exploração manual, aproximando-se do comportamento real de um atacante.

2.2.1. PTES – Penetration Testing Execution Standard

O PTES [Penetration Testing Execution Standard 2014] é uma das metodologias mais amplamente adotadas por profissionais de segurança ofensiva. Ele estrutura um teste de penetração em sete fases sequenciais:

1. **Pre-engagement Interactions:** definição de escopo, objetivos, regras de engajamento e autorizações legais;
2. **Intelligence Gathering:** coleta de informações sobre o alvo por meios passivos (OSINT) e ativos (varreduras diretas);
3. **Threat Modeling:** mapeamento das ameaças mais prováveis com base nas informações coletadas;
4. **Vulnerability Analysis:** identificação e validação de vulnerabilidades na infraestrutura alvo;
5. **Exploitation:** exploração das vulnerabilidades identificadas para obter acesso não autorizado;
6. **Post-Exploitation:** avaliação do impacto do acesso obtido, incluindo movimentação lateral e exfiltração de dados;
7. **Reporting:** documentação detalhada de todas as descobertas, evidências, impacto e recomendações de remediação.

2.2.2. OSSTMM – Open Source Security Testing Methodology Manual

O OSSTMM [Herzog 2010], desenvolvido pelo ISECOM, diferencia-se das demais metodologias por seu foco em métricas quantitativas de segurança. Em vez de apenas listar vulnerabilidades, o OSSTMM propõe a medição da superfície de ataque por meio de uma métrica chamada RAV (*Risk Assessment Values*), que pondera os vetores de acesso disponíveis ao atacante. A metodologia cobre cinco canais de segurança: físico, espectro de

telecomunicações, redes de dados, comunicações sem fio e o canal humano (engenharia social).

2.2.3. NIST SP 800-115

O guia técnico do NIST [National Institute of Standards and Technology 2008] fornece orientações detalhadas para planejamento, execução e geração de relatórios de avaliações de segurança. O documento classifica as técnicas de teste em três categorias: revisão de documentação e configuração, identificação e análise de alvos (varredura), e exploração de vulnerabilidades. Por ser um padrão governamental, é amplamente referenciado em contextos acadêmicos e contratuais.

2.2.4. OWASP Testing Guide

O Guia de Testes da OWASP [OWASP Foundation 2021] é a referência mais completa para testes de segurança em aplicações web. Embora focado em *web apps*, suas técnicas de enumeração de serviços, análise de autenticação e teste de controles de acesso são diretamente aplicáveis ao contexto de redes corporativas que expõem interfaces web, como servidores Apache e IIS com painéis de administração.

2.3. Ferramentas de Pentest

2.3.1. Nmap – Network Mapper

O Nmap [Lyon 2023] é a ferramenta padrão da indústria para descoberta de hosts e serviços em redes. Seu funcionamento baseia-se no envio de pacotes TCP, UDP e ICMP cuidadosamente elaborados e na interpretação das respostas recebidas. Os principais tipos de varredura incluem:

- **SYN Scan** (`-sS`): envia pacotes TCP com a flag SYN e interpreta as respostas. Por não completar o *handshake* TCP, é menos detectável por sistemas de log convencionais;
- **Version Detection** (`-sV`): envia *probes* específicos para identificar o serviço e sua versão, fundamentais para correlação com CVEs conhecidos;
- **OS Detection** (`-O`): analisa características do *stack* TCP/IP para inferir o sistema operacional do alvo;
- **NSE Scripts** (`--script`): motor de scripts em Lua que permite automação de enumeração SMB/LDAP e detecção de vulnerabilidades específicas.

2.3.2. Metasploit Framework

O Metasploit Framework [Kennedy et al. 2011] é a plataforma de exploração de vulnerabilidades mais utilizada no mundo. Sua arquitetura modular é composta por:

- **Exploits**: código que aproveita uma vulnerabilidade específica para executar código arbitrário no sistema alvo, catalogado com referência ao CVE correspondente;

- **Payloads:** código executado após a exploração. O Meterpreter fornece um *shell* interativo em memória com capacidades de *pivoting*, captura de teclado e extração de hashes;
- **Módulos Auxiliares:** scanners, *fuzzers* e ferramentas de enumeração integradas;
- **Módulos de Pós-Exploração:** automação de atividades pós-acesso como extração de credenciais, escalonamento de privilégios e movimentação lateral.

2.3.3. Nessus

O Nessus é um scanner de vulnerabilidades que identifica falhas de segurança por meio de *plugins* especializados. Ao detectar uma versão de software instalada, o Nessus correlaciona com CVEs (*Common Vulnerabilities and Exposures*) e entradas do NVD (*National Vulnerability Database*), classificando as vulnerabilidades por severidade com base no sistema de pontuação CVSS (*Common Vulnerability Scoring System*).

2.3.4. Hydra

O Hydra é uma ferramenta de ataque a mecanismos de autenticação por força bruta e dicionário. Suporta paralelismo em múltiplos serviços simultaneamente, incluindo SSH, RDP, SMB, HTTP, FTP e LDAP. Seu funcionamento consiste em testar sistematicamente combinações de credenciais a partir de listas de palavras (*wordlists*), sendo particularmente eficaz contra sistemas com políticas de senha fracas ou ausência de bloqueio de conta [Weidman 2014].

2.4. Protocolos de Rede Inseguros e Vetores de Ataque

A análise de protocolos de rede é fundamental tanto para a execução de ataques quanto para sua detecção. [Stevens 1994] oferece a descrição mais completa do comportamento dos protocolos TCP/IP, enquanto [Erickson 2008] aborda os aspectos de exploração dessas implementações.

2.4.1. TCP/IP e Handshake de Três Vias

O protocolo TCP [Postel 1981] estabelece conexões por meio de um *handshake* de três vias: o cliente envia um segmento SYN, o servidor responde com SYN/ACK e o cliente confirma com ACK. Esse mecanismo é a base para diversas técnicas de ataque, como SYN Flood (negação de serviço por esgotamento da tabela de conexões semi-abertas), port scanning (análise de respostas SYN para mapear portas abertas) e session hijacking (sequestro de sessões por previsão de números de sequência).

2.4.2. HTTP e Exposição de Credenciais

O protocolo HTTP transmite dados sem criptografia, tornando-o vulnerável a ataques de interceptação. Credenciais enviadas via formulários HTTP, *cookies* de sessão sem as flags `Secure` e `HttpOnly`, e autenticação básica codificada em Base64 são facilmente

capturáveis com ferramentas como o Wireshark [Sanders 2017]. Em redes corporativas onde o HTTPS não é enforcado em todos os sistemas internos, esse vetor representa risco significativo.

2.4.3. DNS e Ataques de Envenenamento

O DNS (*Domain Name System*) [Mockapetris 1987] é um alvo atraente por sua natureza distribuída e pela ausência de autenticação nas implementações tradicionais. Os principais vetores de ataque incluem: DNS Cache Poisoning (inserção de respostas falsas no cache de resolvedores); zone transfer não autorizado (exposição do mapa completo de uma zona DNS via AXFR); e DNS Tunneling (uso do protocolo DNS como canal encoberto para exfiltração de dados ou comunicação com infraestrutura de Comando e Controle).

2.4.4. SMB e Vulnerabilidades em Compartilhamentos Windows

O protocolo SMB é central em redes Windows e historicamente associado a vulnerabilidades críticas. A mais notória é a CVE-2017-0144 [MITRE Corporation 2017], explorada pelo *exploit* EternalBlue, que permite execução remota de código sem autenticação em sistemas com SMBv1 habilitado. Outros vetores incluem Pass-the-Hash (uso de hashes NTLM capturados para autenticação sem conhecimento da senha), relay de NTLM e enumeração de compartilhamentos por acesso anônimo.

2.4.5. LDAP e Active Directory

O LDAP [Sermersheim 2006] é o protocolo subjacente ao Active Directory, o serviço de diretório mais utilizado em ambientes corporativos Windows. Configurações inseguras frequentes incluem: null bind (autenticação anônima que permite enumeração de usuários e grupos sem credenciais); Kerberoasting (solicitação de tickets Kerberos para quebra offline); e AS-REP Roasting (exploração de contas sem pré-autenticação Kerberos).

2.4.6. ARP Spoofing e Ataques Man-in-the-Middle

O protocolo ARP opera sem mecanismos de autenticação, tornando redes locais vulneráveis ao ARP Spoofing. Nessa técnica, o atacante envia respostas ARP falsas associando seu endereço MAC ao IP do gateway padrão, redirecionando o tráfego da vítima por sua máquina [Erickson 2008]. Isso viabiliza ataques Man-in-the-Middle (MitM), possibilitando captura de credenciais, injeção de conteúdo malicioso e SSL Stripping.

2.5. Análise de Tráfego com Wireshark

O Wireshark é o analisador de protocolos de rede mais utilizado no mundo. Segundo [Sanders 2017], a análise de pacotes é uma habilidade fundamental para profissionais de segurança de redes, pois oferece visibilidade completa sobre o que realmente trafega em uma rede, independentemente de logs de aplicação.

2.5.1. Captura e Filtros

O Wireshark opera em modo promíscuo, capturando todos os pacotes que chegam à interface de rede [Wireshark Foundation 2023]. Dois tipos de filtros são fundamentais:

- **Filtros de Captura** (BPF – *Berkeley Packet Filter*): aplicados em tempo real, reduzindo o volume de dados coletados. Exemplo: `host 192.168.1.100 and port 445` captura apenas tráfego SMB de um host específico;
- **Filtros de Exibição**: aplicados após a captura para análise. Exemplo: `tcp.flags.syn == 1 && tcp.flags.ack == 0` isola o início de conexões TCP, útil na detecção de port scanning.

Filtros de exibição especialmente relevantes para detecção de ataques incluem: `arp.duplicate-address-detected` (ARP Spoofing); `http contains "password"` (credenciais em claro); `dns.qry.type == 16` (DNS Tunneling via consultas TXT); e `smb2.cmd == 0x0005` (negociações SMBv2 para detecção de exploração).

2.5.2. Análise Estatística e Identificação de Anomalias

Além da inspeção pacote a pacote, o Wireshark fornece ferramentas estatísticas que permitem identificar padrões anômalos [Sanders 2017]:

- **Protocol Hierarchy**: exibe a distribuição percentual de protocolos; volume incomum de ICMP ou UDP pode indicar varreduras;
- **Conversations**: lista comunicações entre pares de hosts, identificando fluxos de maior volume;
- **IO Graph**: gráfico temporal do tráfego, útil para identificar *spikes* associados a ataques de força bruta;
- **Endpoints**: lista hosts e volume de tráfego, facilitando identificação de comportamentos típicos de port scanning.

2.5.3. Reconstrução de Fluxos e Extração de Artefatos

A funcionalidade *Follow TCP/UDP Stream* permite reconstruir sessões completas de comunicação, sendo útil para recuperar credenciais em texto claro, analisar comandos em sessões de *shell* reverso e identificar comunicação com infraestrutura de C2 [Davidoff and Ham 2012].

A função *Export Objects* complementa essa análise ao extrair arquivos transferidos durante sessões capturadas – imagens, executáveis e documentos transmitidos via HTTP ou SMB podem ser recuperados integralmente dos pacotes, fornecendo evidências forenses cruciais.

2.5.4. Identificação de Padrões Maliciosos Específicos

A literatura especializada [Sanders 2017, Davidoff and Ham 2012] estabelece assinaturas comportamentais no tráfego associadas a técnicas de ataque:

- **Port Scanning:** grande volume de pacotes SYN para múltiplas portas em curto intervalo, com respostas RST da maioria dos destinos;
- **Brute Force:** múltiplas tentativas de autenticação falhas em sequência rápida (respostas HTTP 401 ou SMB de negociação repetidos);
- **EternalBlue:** sequência característica de negociação SMBv1 seguida de *buffer overflow* no campo Transaction2;
- **Meterpreter sobre HTTP/S:** sessões HTTPS para endereços IP externos com intervalos de *keepalive* regulares e tráfego bidirecional em padrão atípico para navegação web normal.

3. Considerações Finais da Fundamentação

A fundamentação teórica apresentada estabelece os alicerces conceituais e metodológicos desta pesquisa. A compreensão da tríade CIA e dos modelos de ameaça fornece o contexto estratégico; as metodologias PTES, OSSTMM e NIST SP 800-115 estruturam a execução rigorosa dos testes; o domínio das ferramentas de pentest viabiliza a simulação fiel de ataques reais; o conhecimento dos protocolos inseguros direciona os vetores a serem explorados; e as técnicas de análise com Wireshark permitem a correlação entre ações do atacante e evidências no tráfego de rede.

As próximas seções detalharão a metodologia adotada, a configuração do ambiente laboratorial e os resultados obtidos na execução prática dos testes de penetração combinados com a análise de tráfego.

Referências

- Davidoff, S. and Ham, J. (2012). *Network Forensics: Tracking Hackers Through Cyberspace*. Prentice Hall, Upper Saddle River, NJ.
- Erickson, J. (2008). *Hacking: The Art of Exploitation*. No Starch Press, San Francisco, 2 edition.
- Herzog, P. (2010). OSSTMM 3 – The Open Source Security Testing Methodology Manual. ISECOM. Disponível em: <https://www.isecom.org/OSSTMM.3.pdf>. Acesso em: maio 2025.
- Kennedy, D., O’Gorman, J., Kearns, D., and Aharoni, M. (2011). *Metasploit: The Penetration Tester’s Guide*. No Starch Press, San Francisco.
- Kindervag, J. (2010). Build security into your network’s dna: The zero trust network architecture. *Forrester Research*.
- Lyon, G. (2023). Nmap Network Scanning: The Official Nmap Project Guide. Disponível em: <https://nmap.org/book>. Acesso em: maio 2025.
- MITRE Corporation (2017). CVE-2017-0144: EternalBlue SMB Remote Windows Kernel Pool Corruption. Disponível em: <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2017-0144>. Acesso em: maio 2025.
- MITRE Corporation (2023). MITRE ATT&CK Enterprise Matrix. Disponível em: <https://attack.mitre.org>. Acesso em: maio 2025.
- Mockapetris, P. (1987). Domain Names – Implementation and Specification. RFC RFC 1035, IETF.

- National Institute of Standards and Technology (2008). Technical guide to information security testing and assessment. Technical Report SP 800-115, NIST, Gaithersburg, MD.
- National Institute of Standards and Technology (2020). Zero trust architecture. Technical Report SP 800-207, NIST, Gaithersburg, MD.
- OWASP Foundation (2021). OWASP Testing Guide v4.2. Disponível em: <https://owasp.org/www-project-web-security-testing-guide>. Acesso em: maio 2025.
- Penetration Testing Execution Standard (2014). PTES Technical Guidelines. Disponível em: <http://www.pentest-standard.org>. Acesso em: maio 2025.
- Postel, J. (1981). Transmission Control Protocol. RFC RFC 793, IETF.
- Sanders, C. (2017). *Practical Packet Analysis: Using Wireshark to Solve Real-World Network Problems*. No Starch Press, San Francisco, 3 edition.
- Sermersheim, J. (2006). Lightweight Directory Access Protocol (LDAP): The Protocol. RFC RFC 4511, IETF.
- Shostack, A. (2014). Threat modeling: Designing for security.
- Stallings, W. (2017). *Network Security Essentials: Applications and Standards*. Pearson, New Jersey, 6 edition.
- Stevens, W. R. (1994). *TCP/IP Illustrated, Volume 1: The Protocols*. Addison-Wesley, Reading, MA.
- Weidman, G. (2014). *Penetration Testing: A Hands-On Introduction to Hacking*. No Starch Press, San Francisco.
- Wireshark Foundation (2023). Wireshark User's Guide. Disponível em: https://www.wireshark.org/docs/wsug_html_chunked. Acesso em: maio 2025.